

Authentication Labs

Authentication is the process of verifying the identity of a user or client

Something

you know - password /answer to security question - knowledge factors

You have - physical object such as a mobile phone or security token - Possession factors

you are/do - biometrics or patterns of behavior. - Inherence Factors

Summary

Vulnerabilities can be in different forms of authentication

- Password, Multi factor Authentication , Password reset, Staylogged in cookie , Forgot password .

These columns are key indicators for status of an attack : Status codes,Error messages.length,response received and response completed

Always inspect and directly access sensitive URL endpoints after the first authentication step. Verify whether it can be accessed before completing 2FA as url manipulation can lead to 2FA bypass

Identify any security-sensitive tokens in requests or URLs (e.g., password reset tokens, email verification tokens, MFA tokens). Verify whether the backend actually validates them. Try removing, modifying, reusing, or replacing the token and observe whether the application still processes the request successfully

Usage of Intruder powers for identifying indicators of compromise (IOC)

Grep Match - To check whether specific text exists in the response - (Count of Matches)

Grep Extract - Extract specific data from the response - Actual Text

To bypass ip-blocking bruteforce protection use
X-Forwarded-For:1 header as it spoofs the client ip address
and enumerate the usernames and passwords with having an eye on response received, response sent and status code

use of maximum concurrent requests of resource pool
some applications behave differently when requests arrive:

One at a time, in parallel, in large bursts

Maximum concurrent requests can be modified accordingly

If set to 1 (burp sends the request and waits for the response)

If set to 10 (burp sends all 10 requests at once and waits for the response)

By using this we can control the time of operations in the request

Null payloads generate sufficient attack iterations without modifying the request and also useful in the cases of username enumeration where existence of rate limiting is present so username gets repeated.

Bruteforce the mfa-code parameter if possible by the bruteforcer of intruder tab include only numbers digits range from (4-6) (4-10000 combinations) (6 - 1000000 combinations)

Inspect the structure of "Remember Me" / "Stay Logged In" cookies. Determine whether the cookie contains predictable or sensitive data such as usernames, password hashes, user IDs, timestamps, or tokens encoded with Base64 or other reversible formats.

For ex: `base64(username+'!'+md5HashOfPassword)`

X-Forwarded-Host (XFH) is an HTTP header that identifies the original host requested by the client. When web applications blindly trust this header for routing, caching, or URL generation without validation, it leads to several critical vulnerabilities, most notably HTTP Host Header Injection

When testing a login endpoint that accepts JSON input, verify whether the application correctly validates the data type of each parameter. Some applications may process arrays, objects, or unexpected JSON structures differently from simple strings.

Bruteforce password with the json curated list of passwords

```
"username" : "carlos",
```

```
"password" : [
```

```
  "123456",
```

```
  "password",
```

```
  "qwerty"
```

```
  ...
```

```
]
```